Advanced IT Security

Joachim Posegga

Chair of IT Security

Agenda

0 Basics

1 Symmetric Cryptography

2 Asymmetric Schemes (PKI)

3 Authentication

4 Access Control

5 Crypto-Protocols

6 „real-life“ Protocols:

- SSL/SSH
- possibly others (depending on time left)

© J. Posegga, PIDS

Why, after all, do we need Security?

Because some ~~people~~ LLMs do not behave as we want them to!



© J. Posegga, PIDS

What does Security Mean?

"X is secure" is meaningless as an isolated statement:

- A system can only be secure *against* something
  - First job: Identify threats and security goals
- Security is a relative notion
  - "How much effort (time, money,…) does an attacker have to invest to compromise a system
  - Cost/benefit ration of security investment is a must!
- Security technology = technical means for risk management

© J. Posegga, PIDS

Elements of Security

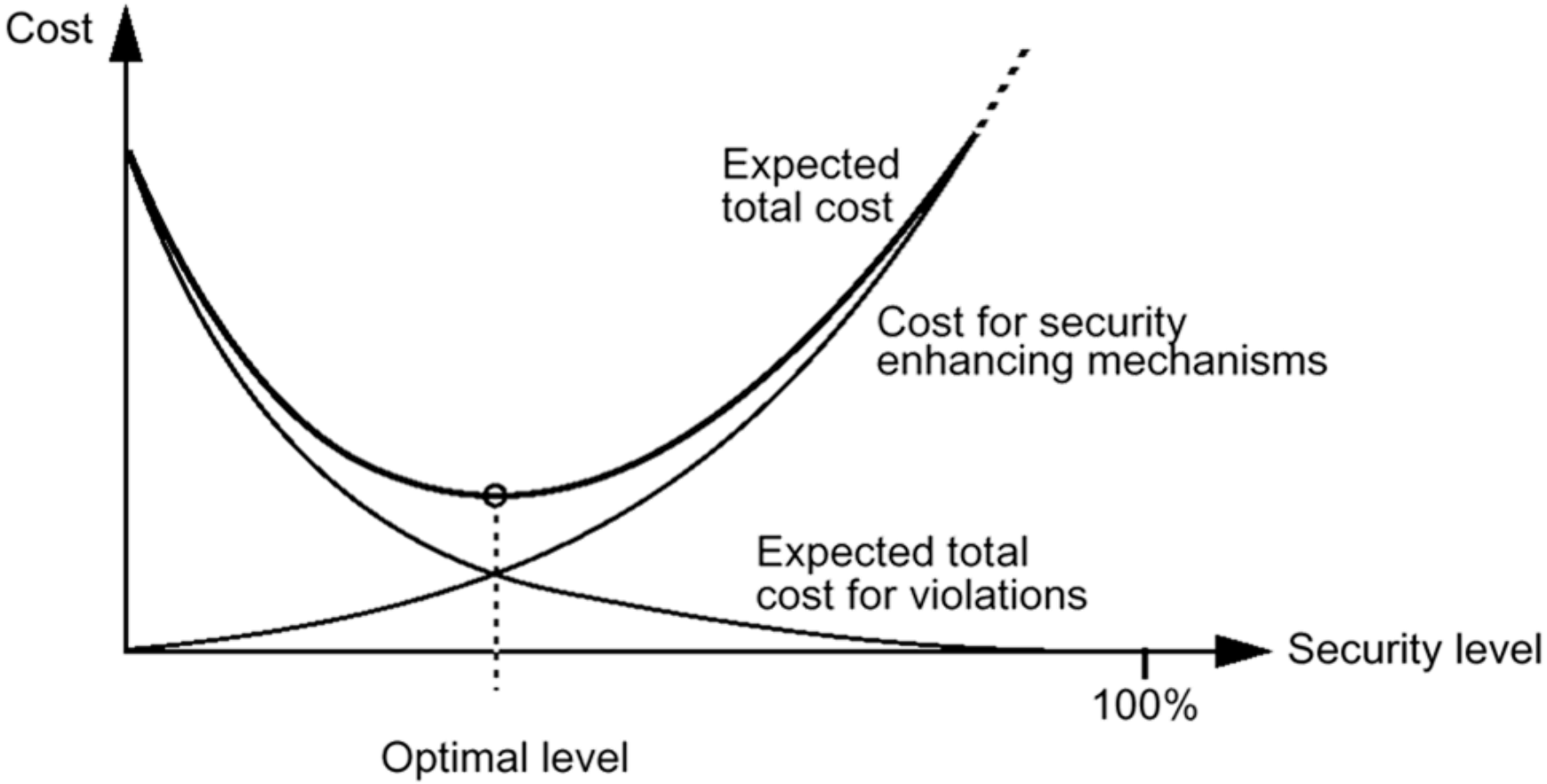
Policy: ***Specifying*** **security**
What is it supposed to do?

Mechanism: ***Implementing*** **security**
How does it do it?

Assurance: ***Correctness*** **of security**
Does it really work?

© J. Posegga, PIDS

Cost vs. benefit



© J. Posegga, PIDS

General Remarks on Risk

People perform extremely poorly with managing technical risk

Risk and emotion are inseparable.

- We fear spectacular, unlikely events
- Anything new is suspicious
- Anything invisible is suspicious
- Correlation is often confused with causality

Greater Fear	Less Fear
Imposed (nuclear accident radiation)	**Voluntary** (medical radiation)
More **Pain and Suffering** (cancer)	Less **Pain and Suffering** (heart disease)
Human-made (radiation from technology)	**Natural** (radiation from the sun)
Less Benefit (vaccines for diseases that have been mostly eliminated)	**More Benefit** (vaccines for new strains of influenza – H1N1/"Swine flu")
Uncertainty (nuclear radiation - because we can't detect it, science doesn't have all the answers, or we don't understand all the science.)	**Certainty/Familiarity** – (motor vehicle crashes)
Risks to Children (childhood vaccines)	**Risks to Adults** (adult vaccines)

Slovic P, The Perception of Risk, Earthscan 2000

© J. Posegga, PIDS

Risk Perception

What's more common in the United States, (a) suicide or (b) homicide?

Who has a higher risk of being murdered: Women or men?

Global victims: female 21%, male 79%

What is the top cause of accidental death in America, following motor-vehicle accidents?

Drug overdose

Of the top two causes of non-accidental death in America, (a) cancer and (b) heart disease, which kills more women?

© J. Posegga, PIDS

Risk Perception

Worldwide annual fatalities:

Shark attacks = 10

Getting hit on the head with a coconut = 150

The per-flight risk of dying in a commercial airline crash between 2000 and 2007 was 1 in 80 million

The per-trip risk of dying in an automobile crash, given the average American car trip of 6 miles, was 1 in 14.6 million.

95 % of people who are involved in a plane crash survive





© J. Posegga, PIDS

… for the sake of confusion:

Germany 2008: deaths per billion km and year (OECD)

- **Rail:** 0.2
- **Air:** 0.4
- **Motorcycle:** 45
- **Car:** 6
- **Bycyle:** 30
- **Pedestrian:** 38

Actual number of deaths (2012):

Road User Type		
	Motorcycles	583
	Passenger Cars	1 655
	Cyclists	387
	Pedestrians	453

© J. Posegga, PIDS

GSM-Security: Political Constraints

Export of Cryptographic Technology:

- An internationally rolled out system (Roaming!) must comply with international regulations regarding export control

“Lawful Interception”:

- Goernment regulations require to provide means for certain authorities to intercept data.

Examples:

- IMSI-Catcher (“man-in-the-middle attack”) are possible since the GSM network does not authenticate against the client.
- Access to the history of location information tells a lot!

© J. Posegga, PIDS

Definitions

© J. Posegga, PIDS

Elements auf Security...

- assets,
- threats,
- vulnerabilities,
- impact,
- risk,
- safeguards,
- residual risk,
- constraints.

© J. Posegga, PIDS

Assets...

Everything that has a value

- Information and Data,
- Hardware,
- Software,
- other Equipment,
- documents,
- services,
- “trust” in services,
- personell,
- A organization’s image,...

© J. Posegga, PIDS

Threats

Everything that potentially harms Assets

- errors, faults,
- misuse and theft,
- malicious code,
- hacking,
- sabotage,
- espionage,...

© J. Posegga, PIDS

Vulnerabilities

"Vulnerabilities are weaknesses which allow a threat to occur"

(Vulns do not neccesarily cause damage)

Examples:

- Insecure communication,
- Poorly trained staff,
- Trivial passwords,
- Poor access control,
- Lack of Back-ups,...

© J. Posegga, PIDS

Safeguards

Means to reduce threats or vulnerabilities

Example: Access Control, Encryption, training of personell,...

- ETSI Baseline Security Standard
- NIST Computer Security Handbook
- ISO TC 68 Banking and Related Financial Services - Information Security Guidelines
- ...

© J. Posegga, PIDS

Risks...

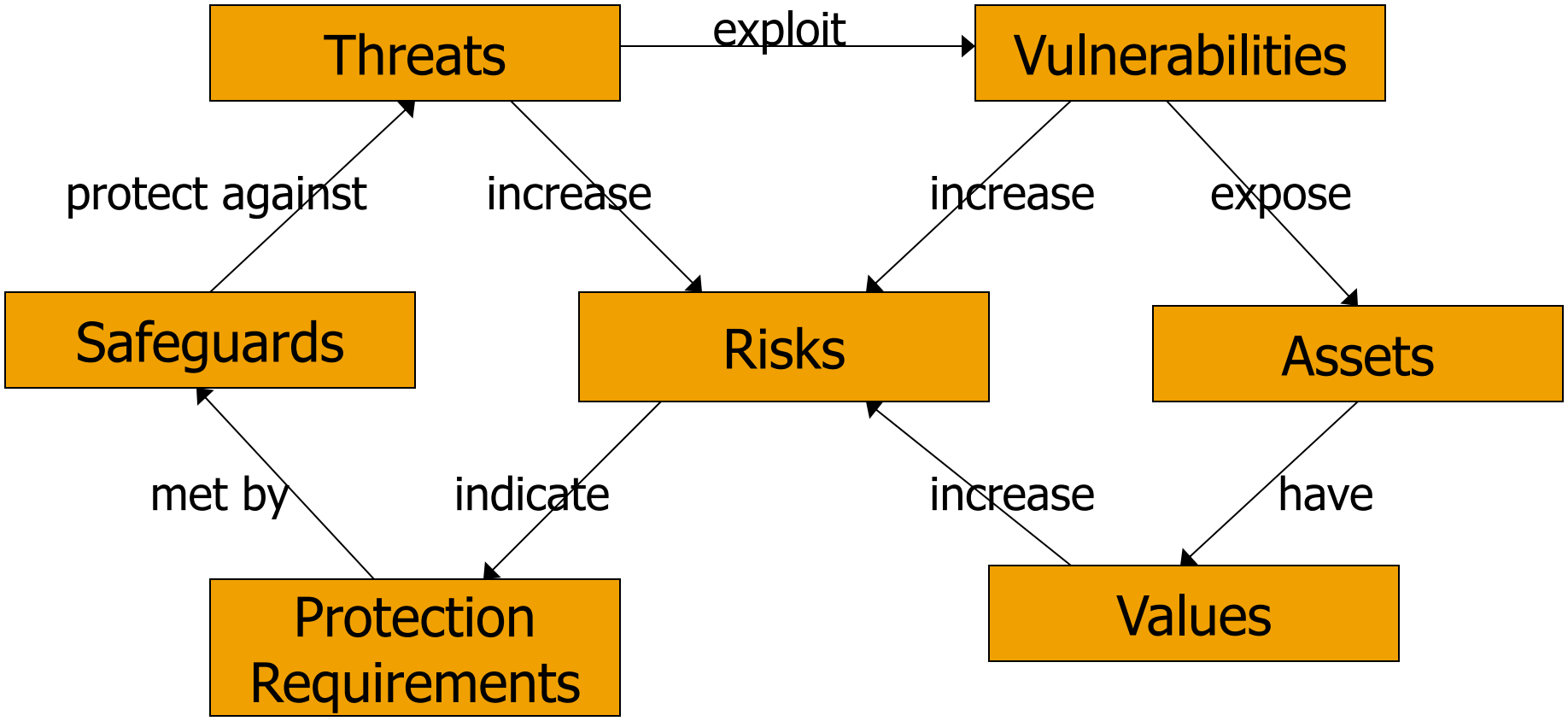
Risk is a Function of:

- Assets,
- Threats,
- Vulnerabilities,
- Safeguards.

There always remains a Residual Risk

© J. Posegga, PIDS

Beziehungen



© J. Posegga, PIDS

Basic Notions

Confidentiality: no unauthorized access to Information

Integrity: no unauthorized modification of information / resources

Availability: no unauthorized denial of access to information / resources

(according to ITSEC)

© J. Posegga, PIDS

Confidentiality

Historically, security and secrecy were closely related. Sometimes, security and confidentiality are used as synonyms

- **Prevent unauthorised disclosure of information (prevent unauthorised reading)**
- **Privacy: protection of personal data**
- **Secrecy: protection of data belonging to an organisation**

© J. Posegga, PIDS

Integrity

Everyting is as it is supposed to be...

© J. Posegga, PIDS

Integrity – Other definitions – Overview

Property or state, or?

Clark and Wilson: No user of the system, even if authorized, may be permitted to modify data items in such a way that assets or accounting records of the company are lost or corrupted.

Orange Book (TCSEC): Data Integrity - The state that exists when computerized data is the same as that in the source document and has not been exposed to accidental or malicious alteration or destruction.

In communications: detection (and correction) of modifications of transmitted data, including both intentional modifications and random transmission errors.

ISO 7498-2: The property that information has not been modified or destroyed in an unauthorized manner.

ISO 27000: property of accuracy and completeness

RFC 4949: The property that data has not been changed, destroyed, or lost in an unauthorized or accidental manner.

© J. Posegga, PIDS

Is Integrity a property or a state?

Property is any characteristic or attribute which can be quantitatively evaluated.

- Examples from physics: pressure, temperature, velocity, energy, etc. are all properties

The **state** of an object is its condition described by a list of properties.

- Example: temperature and pressure may describe the state of a gas

View on Integrity:

Integrity is a property (of data, of a system, of hardware,…)

Data Integrity is a specific state of data that is verifiable.

© J. Posegga, PIDS

Integrity – Other definitions – Overview

Detection or prevention ?

Clark and Wilson: No user of the system, even if authorized, may be permitted to modify data items in such a way that assets or accounting records of the company are lost or corrupted.

Orange Book (TCSEC): Data Integrity - The state that exists when computerized data is the same as that in the source document and has not been exposed to accidental or malicious alteration or destruction.

In communications: detection (and correction) of modifications of transmitted data, including both intentional modifications and random transmission errors.

ISO 7498-2: The property that information has not been modified or destroyed in an unauthorized manner.

ISO 27000: property of accuracy and completeness

RFC 4949: The property that data has not been changed, destroyed, or lost in an unauthorized or accidental manner.

© J. Posegga, PIDS

Other definitions – Overview

What to detect ?

Clark and Wilson: No user of the system, even if authorized, may be permitted to modify data items in such a way that assets or accounting records of the company are lost or corrupted. ← Preventative

Orange Book (TCSEC): Data Integrity - The state that exists when computerized data is the same as that in the source document and has not been exposed to accidental or malicious alteration or destruction.

In communications: detection (and correction) of modifications of transmitted data, including both intentional modifications and random transmission errors.

ISO 7498-2: The property that information has not been modified or destroyed in an unauthorized manner.

ISO 27000: property of accuracy and completeness

RFC 4949: The property that data has not been changed, destroyed, or lost in an unauthorized or accidental manner.

© J. Posegga, PIDS

Internal vs. external consistency

Note 3: Integrity definition sees data integrity as “a specific invariant on data” [ISO 10181-6]. Following this, the integrity protection mechanism “detects the violation of internal consistency” [ISO 10181-6]. “A datum is internally consistent if and only if all modifications of this item satisfy the relevant integrity security policies.” [ISO 10181-6]

Note 4: Integrity definition is not concerned with the external consistency or veracity of the data.

Q: Assume a temperature sensor that is attached to an IoT device is broken, i.e. readings are too high.

Assume the IoT device signs the temperature measurements data, i.e. readings are digitally signed.

Should an integrity verification of the signed but wrong temperature value fail or succeed?

© J. Posegga, PIDS

Availability

- ISO 7498-2: the property of being accessible and usable upon demand by an authorised entity

- Denial of Service: The prevention of authorised access of resources or the delaying of time-critical operations

-> Denial-of-Service is hard to prevent in real life!

© J. Posegga, PIDS

Security Evaluation

"Security evaluation checks whether a product delivers a promised security service. We have to state the function of the security system the required degree of assurance (trust) in its security"

(D. Gollmann)

- **A high level of Assurance-Level implies an inspection of a system at a very detailed level.**
- **Complex systems and a high levels of assurance tend to me mutually exclusive**

© J. Posegga, PIDS

© J. Posegga, PIDS

Specification of Security Properties of a System

- Define goals that can be reached with security measures
- Often written down in Natural language
- Should be aligned with the real world the refer to

  Example: Two employees are needed to open the safe with confidential documents; only possible between 9am and 4 pm

  -> An electronic system might enfoce an equivalent policy

© J. Posegga, PIDS

More Security Properties

Many more security properties and security services to achieve them are defined in the literature ...

- **use them when defining your system‘s security policy**
- **but make sure they are precisely defined**
- **but make sure the real world attacks map to the explicitly defined attacker model**
- **be aware of the subtle differences**



© J. Posegga, PIDS

Data origin authentication – Differences and Relations

Data origin authentication is the assurance that a given entity was the original source of received data.

Data integrity is the assurance that data has not been altered in an unauthorised (which includes accidental) manner.

Note: Different from Integrity, see the following relation:

"Data origin authentication is a stronger notion than data integrity"

"Confidentiality does not imply data origin authentication"

"Confidentiality does not imply data integrity"

Definitions / Examples / Relations by Keith Martin
taken from Everyday Cryptography: Fundamental Principles and Applications

© J. Posegga, PIDS

The Dual of Integrity – Different from "No Integrity"

The constructed Dual* of Integrity is Contingency

*) Duality in this case means that information can only be in the state of *integrity* or in the state of *contingency*, but data cannot be in both, as this would be a contradiction.

Contingency describes the verifiable state that the data's integrity is intended to be unknown. Data in that state is said to be contingent.

Definition by Andreas Pfitzmann & Martin Rost taken from "Datenschutz-Schutzziele – revisited"
Originally in German: "*Kontingenz*: Information ist […] gesichert nicht gesichert echt."

- Contingency is a verifiable property explicitly established by the applied protection mechanism and not an accidental state.
- Allows an entity to repudiate the data, but not its creation
- Data origin authentication is required for "intend" to be meaningful

© J. Posegga, PIDS

Non-Repudiation – Differences and Relations

Non-Repudiation is the assurance that an entity cannot deny a previous commitment or action.

Most commonly, non-repudiation is the assurance that the original source of some data cannot deny to a third party that this is the case.

Note: Slightly different from Data origin authentication, as follows

> "Data origin authentication is the assurance that a given entity was the original source of received data."

> "Non-repudiation of a source is a stronger notion than data origin authentication"

Definitions / Examples / Relations by Keith Martin
taken from Everyday Cryptography: Fundamental Principles and Applications

© J. Posegga, PIDS

Entity Authentication – Differences and Relations

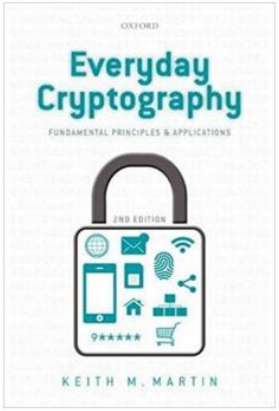
Entity-Authentication is the assurance that a given entity is **involved and currently active** in a communication session.

Note: **Different from Data origin authentication**, as follows

"**Data origin authentication** on its own is only concerned with the origin of data, not whether the sender of data is currently active."

"Data origin authentication **plus a freshness check** can provide entity authentication"

Definitions / Examples / Relations by Keith Martin taken from "Everyday Cryptography: Fundamental Principles and Applications"



© J. Posegga, PIDS

Classifying Attackers

Class I: “Clever Outsiders”. Intelligent, has technical knowledge and simple equipment. Tend to use known vulnerabilities of systems

Class II: “Knowledgeable Insiders”. Technical Training/Education, in-depth knowledge of systems, has access to sophisticated equipment

Class III: “Funded Organizations”. Teams of specialists, access to relevant (Insider-) Information, access to dedicated euquipment and significant resources (time, money, personnel)

[Abraham, Dolan, Double, Stevens: Transaction Security System, IBM Systems Journal, 30(2), 1991.]

© J. Posegga, PIDS

Security in Computer Science

Standard Answer (until 2000):

- Cryptography (initiated originally from military needs)

Today's Sub-fields:

- Cryptography (Encryption, Authentication, Watermarking; Algorithms, Protocols; PKI;...)
- Software-Engineering (Avoiding Bugs, Secure Coding, Evaluation/Certification,...)
- Platform-Security, Security-Architectures (OS, Browser, Java etc.)
- Internet- and Web-Security (bugs in protocols, secure Web-Server and -Browser, Firewalls, online Payments,...)
- Hardware-Security (Smartcards, Secure Tokens, etc.
- ...

© J. Posegga, PIDS

Some Example Approaches to Security

- Virtualization: Giving code the illusion that it is in an environment other than the one it is actually being executed on.
- Attestation: Providing systems the means to attest or verify the integrity of their components. (Needs a root of “trust”)
- Acceleration: Adding hardware support to reduce the runtime overheads of security features.
- Tagging: Memory locations are “tagged” with metadata, which can signal things like data types or permission levels.
- Formal methods: Construct logical proofs to verify or disprove certain properties about a system.
- Cryptography: Encrypt/protect information using cryptosystems.
- Isolation: Keep trusted and untrusted components separate from each other, and carefully monitor any interaction between the two.
- Flow Approaches: Everything is an object with data and metadata. As computations are applied to data, shadow computations occur on the corresponding metadata, which detect and report illegitimate data modifications.

© J. Posegga, PIDS

https://www.sigarch.org/are-computer-architects-to-blame-for-the-state-of-security-today/

Some Example Approaches to Security

- Moving Target Approaches: Almost all attacks (will) have defenses, and all defenses (will) have attacks. If attackers and defenders are constantly trying to better each other, moving target approaches minimize the advantage to the attackers by changing how the system/defenses work over time.
- Diversification: If each system were distinct, it would force the attacker to prepare bespoke exploits, increasing their work and reducing their profits.
- Anomaly detection: This paradigm is borne out of the philosophy that systems will always be insecure, irrespective of the presence of other security mechanisms. The goal is to monitor systems for abnormal or unusual behavior, which may indicate an adversarial attack on a system's security.
- …

© J. Posegga, PIDS

https://www.sigarch.org/are-computer-architects-to-blame-for-the-state-of-security-today/

Private phone calls?

A Smartphone is a…

- uniquely identified device (IMEI, IMSI, WLAN-MAC,…)
- real-time geo-location tracking device (GPS & WLAN beacons)
- remote listening device (voice & sound fingerprinting)
- storage for intimate secrets (Email, Pictures)
- monitor for the owner's behavior (gait analysis)
- everything you do with a phone (calls, messages, pictures, motion,...) can be monitored, collected, and archived

How would you make a private phone call?

© J. Posegga, PIDS

Cell Phone OPSEC

Rules for both peers, allow for a larger time delay before operation:

- **Exchange OTP string (direct or at least with tamper-evident package);**
- **Analyze your daily movements, paying attention to anchor points (home or work) and dormant periods in schedules (8-12 p.m. or when cell phones aren't changing locations);**
- **Leave your daily cell phone behind during dormant periods and purchase a prepaid no-contract cell phone ("burner phone") months ahead;**
- **Phone should be as dumb as possible, choose a small shop without surveillance cams;**
- **Pay with cash, pay attention to where the cash comes from;**
- **Never turn the phone on in, or around your home. Take the battery out when it’s not being used;**

© J. Posegga, PIDS

Cell Phone OPSEC

- Encrypt the cell phone number using a onetime pad (OTP) system and rename an image file with the encrypted code.
- Using Tor to hide your web traffic, post the image to an agreed upon account (twitter, facebook,…), which signals a communications request to your partner;
- Leave cell phone behind, avoid anchor points, and receive phone call (no SMS) from partner on burner phone at a pre-arranged "dormant" time on the following day;
- Use a speech generator to say the words you want to exchange;
- Prefer signaling over operational data:
  signaling > open codes > plain talk
- Wipe down and destroy handset, dispose with extreme prejudice

© J. Posegga, PIDS